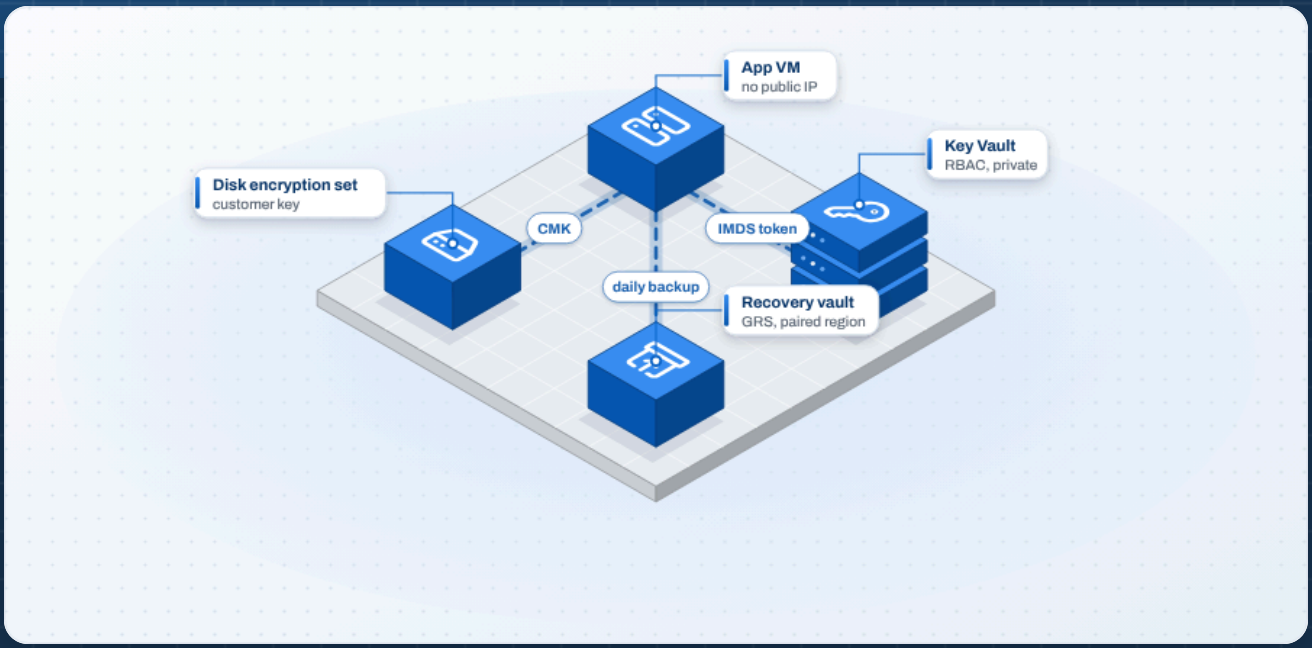
STANDARD OPERATING PROCEDURE · FIELD GUIDE SERIES

SOP-AZ-102

Deploying a Repeatable Customer Stamp

One template per new customer: a private spoke network, Key Vault read by the VM managed identity, customer-managed disk keys and geo-redundant backup to the paired region.

Cloud Infrastructure | Key Vault | Managed Identity



DOCUMENT ID	SOP-AZ-102
VERSION	1.1
EFFECTIVE	October 2026
AUDIENCE	Platform engineers, customer operations, security reviewers
AUTHOR	Richmond Dieujuste, Principal Consultant

Rich Dieu IT Solutions LLC · richdieu.com

Sanitized reference edition · client identifiers removed

Contents

1. Concepts You Need First 2

1.1 How the VM reads its secrets 2

1.2 Encryption and backup 3

2. Access, Prerequisites and Planning 4

2.1 Level of access required 4

2.2 Prerequisites checklist 4

2.3 Decisions to make up front 4

3. Procedure in the Azure Portal 6

4. Template · Stamp as Code 10

5. Verification and Troubleshooting 13

5.1 Verify the stamp 13

5.2 Troubleshooting 13

5.3 Rollback 13

6. Summary, Glossary and Review 14

6.1 Chapter summary 14

6.2 Glossary 14

6.3 Framework references 14

LEARNING OBJECTIVES

After working through this procedure you will be able to:

- Explain the VM to IMDS to Key Vault secrets flow and why no secret is ever written to disk.
- Deploy a stamp in the portal and from the template on top of the SOP-AZ-101 foundation.
- Prove the exit criterion: no public IP on the VM, vault read by the VM identity only, GRS backup with cross-region restore.

CHAPTER 1

Concepts You Need First

A **stamp** is one identical, isolated unit per customer: its own resource group, spoke network, VM, vault and backup. Because every stamp comes from the same template, the tenth customer is as well built as the first, and a reviewer who has checked one stamp knows what every other stamp looks like.

> **KEY CONCEPT · A SAFE-DEPOSIT BOX, NOT A KEY UNDER THE MAT**
>
> Secrets live in the vault, the way valuables live in a bank's safe-deposit box. The VM does not carry the key; it proves who it is at the counter (IMDS), receives a short-lived ticket, and reads only the box it is allowed to read. Nobody leaves a password in a file on the server.

1.1 How the VM reads its secrets

1. At service start the VM asks the **Instance Metadata Service (IMDS)** at `169.254.169.254` for a token for its system-assigned managed identity.
2. It calls the vault over the **private endpoint** with that token. Public network access to the vault is disabled.
3. The vault checks the role: **Key Vault Secrets User** lets the identity read secret values and nothing else.
4. The service writes the values into a tmpfs file readable only by the service user; they disappear at reboot.

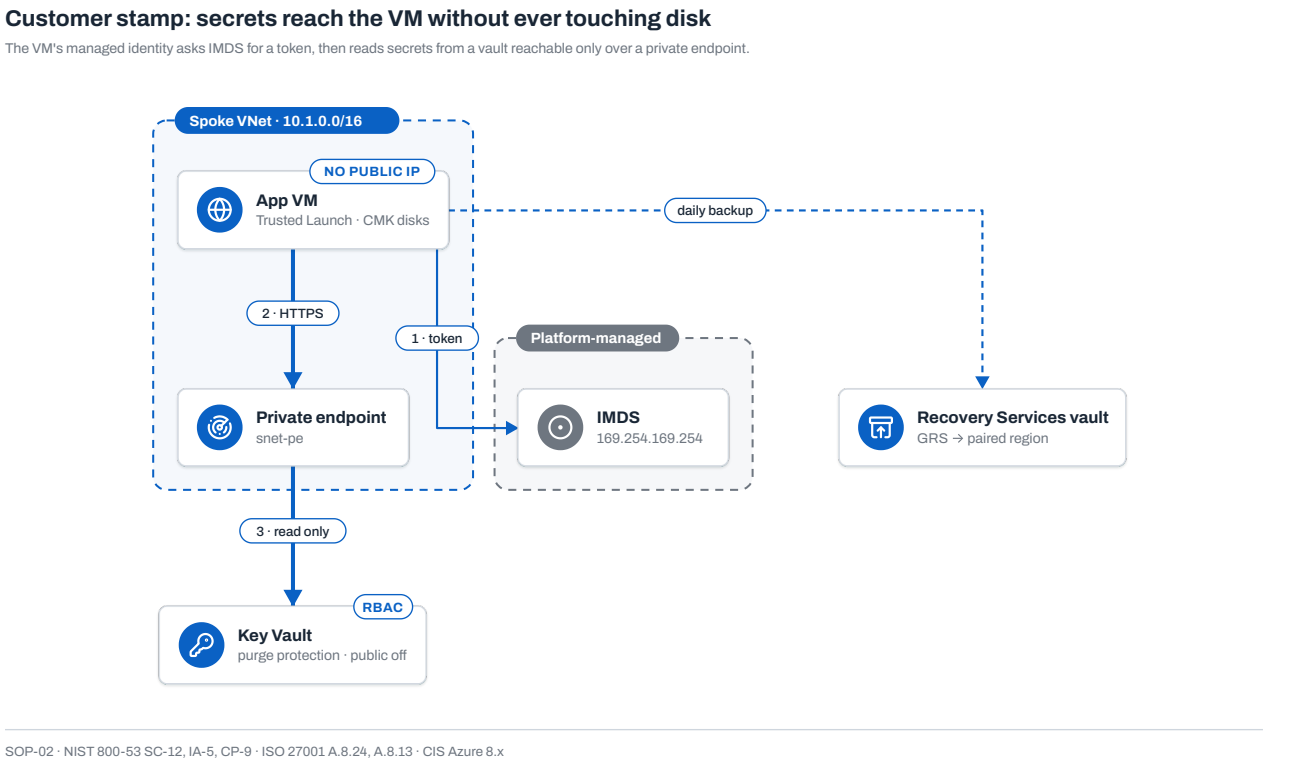


Figure 1. Secrets reach the VM through IMDS and the private endpoint; backup leaves the stamp only for the paired region.

1.2 Encryption and backup

Layer	Control	Why
Disks	Disk encryption set with a customer-managed RSA 3072 HSM key, double encryption, auto rotation	The client can revoke the key and every disk becomes unreadable
Host	Encryption at host	Temp disk and caches are encrypted too
Boot	Trusted Launch with Secure Boot and vTPM	Blocks boot-level malware
Backup	Recovery Services vault, geo-redundant, cross-region restore, immutable (unlocked)	Copies are never held only at the same site as the tenant

CHAPTER 2

Access, Prerequisites and Planning

2.1 Level of access required

Grant the narrowest role that does the job, for the shortest time. Where a role is only needed for one step, activate it through Privileged Identity Management for that step and let it expire.

Task	Least-privilege role	Notes
Create the stamp resources	Contributor on the customer subscription	Foundation from SOP-AZ-101 must exist
Grant the VM and disk set vault roles	User Access Administrator on the stamp resource group	Or Owner; limit to the stamp resource group
Seed secrets during the build	Key Vault Secrets Officer, temporary	Removed by the hardening pass at the end of the run
Operate the stamp after hand-over	Customer operations group, eligible Contributor on Customers	Through PIM, see SOP-AZ-104

CAUTION · REDUNDANCY LOCKS ONCE ANYTHING IS PROTECTED

A Recovery Services vault's storage redundancy cannot change after the first item is protected. Set Geo-redundant and cross-region restore before enabling backup for the VM, or you will stop protection, change it and start again.

2.2 Prerequisites checklist

- [ ] VM family quota available in the region for the chosen size (check **Subscriptions › Usage + quotas**).
- [ ] The chosen size is not capacity-restricted for the subscription in the region.
- [ ] EncryptionAtHost feature registered on the subscription.
- [ ] Customer code chosen (for example `c001`); spoke address space does not overlap the hub or other stamps.
- [ ] Application port and the gateway subnet that may reach it agreed with the app team.

2.3 Decisions to make up front

Decision	Guidance
VM size	Pick a size with quota and no capacity restriction; newer v6 sizes need the NVMe disk controller.

Decision	Guidance
Egress	A NAT gateway gives a fixed outbound IP. If the design needs an FQDN allow-list, plan Azure Firewall instead.
Who writes secrets later	A person with Secrets Officer, through an in-network path or a short selected-networks window. The VM stays read-only.

CHAPTER 3

Procedure in the Azure Portal

NOTE · HOW THESE SCREENS WERE CAPTURED

Screens in this chapter were captured read-only from a live engagement tenant. Client, product and people names, tenant, subscription and object IDs, email addresses and public IPs are replaced (`org`, `app`, `Contoso`, `00000000-…`, `203.0.113.10`). Compliance figures and unrelated rows are blurred. Portal labels move over time; the setting names are what matter.

STEP 1 Create the spoke network and NSG

1. Create the stamp resource group with the three required tags.
2. Create a **Network security group** with: SSH 22 from the hub management subnet only, the app port from the gateway subnet only, deny Internet inbound at 4000, HTTPS 443 out to AzureCloud, deny all outbound at 4000.
3. Create the spoke **Virtual network** with `snet-app` (NSG attached) and `snet-pe`, then add **Peerings** both ways with the hub.

STEP 2 Create the Key Vault

1. **Key vaults › Create**. Pricing tier **Premium**, soft delete 90 days, **Purge protection: Enable**.
2. On **Access configuration** choose **Azure role-based access control**.
3. On **Networking** choose **Disable public access** and add a **private endpoint** in `snet-pe` with private DNS integration.

STEP 3 Create the key and the disk encryption set

1. In the vault create an RSA 3072 HSM key with an expiry date.
2. **Disk Encryption Sets › Create:** encryption type **Double encryption with platform-managed and customer-managed keys**; select the vault and key; turn on **Auto key rotation**.
3. Grant the set's identity **Key Vault Crypto Service Encryption User** on the vault when prompted.

STEP 4 Create the VM

1. **Virtual machines › Create.** Security type **Trusted launch** with Secure Boot and vTPM.
2. **Disks**: Encryption at host on; key management **Customer-managed key** with the encryption set; add a data disk on the same set.
3. **Networking**: subnet `snet-app`, **Public IP: None**, NIC network security group **None** (the subnet NSG applies).
4. **Management**: **Enable system assigned managed identity**; patch orchestration **Azure orchestrated**.

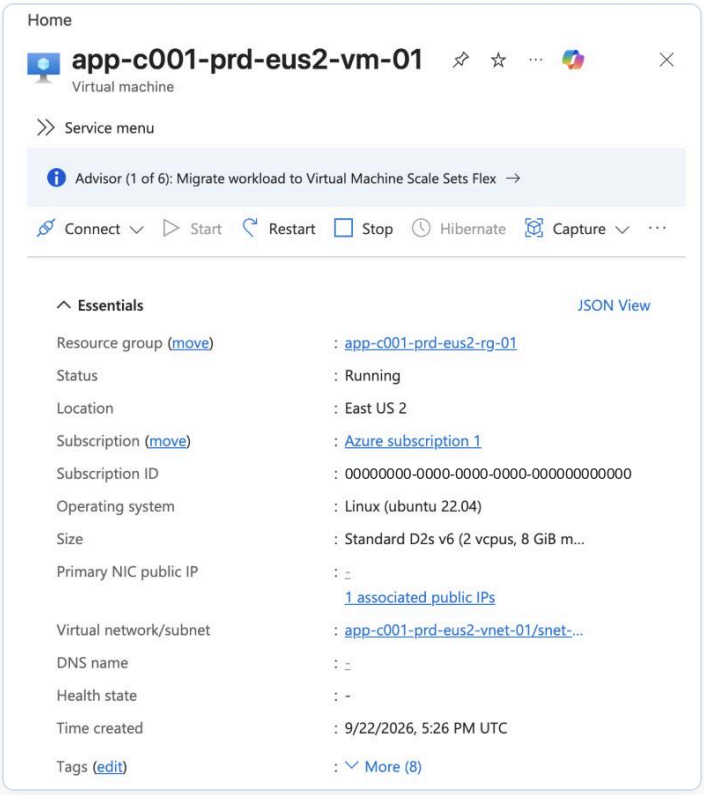


Figure 2. The deployed VM: no public IP on its NIC. The one associated public IP belongs to the NAT gateway used for egress.

STEP 5 Give the VM read-only access to secrets

1. Open the vault › **Access control (IAM) › Add › Add role assignment.**
2. Role **Key Vault Secrets User**; **Assign access to: Managed identity**; select the VM.
3. Give the VM no other vault role. The service reads secrets at start through IMDS (see `fetch-secrets.template.sh`).

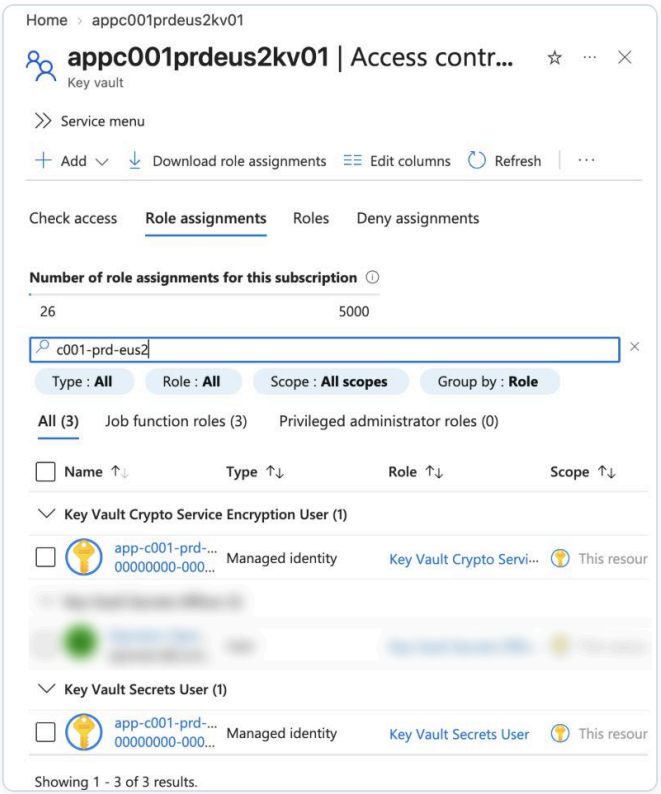


Figure 3. Vault roles filtered to the stamp: the disk set holds the crypto role, the VM identity holds Secrets User only. Other rows blurred.

> **GOOD PRACTICE · NAMES, NEVER VALUES**
>
> Evidence for the vault lists secret names, enabled state and expiry only. Never export or screenshot a secret value.

STEP 6 Configure geo-redundant backup

1. Create a **Recovery Services vault**. Before protecting anything open **Properties › Backup Configuration** and select **Update**.
2. Set **Geo-redundant** and **Cross Region Restore: Enabled**, then **Apply**.
3. Turn on **Immutable vault** (unlocked) and set public network access to disabled.
4. Pre-create the tagged `AzureBackupRG_<region>_1` resource group so the tag policy does not refuse the snapshot group, then enable backup for the VM with a daily policy.

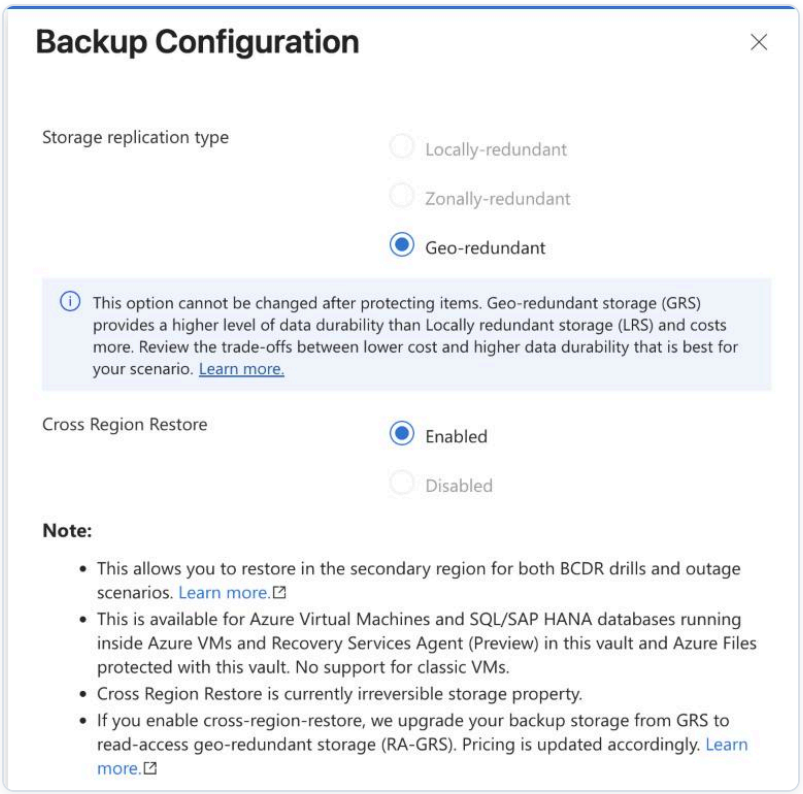


Figure 4. Backup configuration read back: geo-redundant storage and cross-region restore, both locked once items are protected.

CHAPTER 4

Template · Stamp as Code

One parameter, `customerCode`, separates one customer's stamp from the next. The template builds the stamp in the order above, then a hardening pass closes any bootstrap window and removes the operator's temporary vault role, even if a step fails part way.

SOP-02-CUSTOMER-STAMP.PS1 · CUSTOMER STAMP · BASE TEMPLATE POWERSHELL

```powershell
<#  SOP-02 template: repeatable customer stamp (spoke, NSGs, Key Vault + managed identity, CMK, VM, GRS backup)
    One parameter (customerCode) per new customer. Run after SOP-01. Sanitized pattern.        #>
[CmdletBinding(SupportsShouldProcess)]
param([Parameter(Mandatory)][string]$ParameterFile)
$ErrorActionPreference = 'Stop'
$cfg = Get-Content $ParameterFile -Raw | ConvertFrom-Json
$c   = $cfg.customerCode
function N($t) { ('{0}-{1}-{2}-eus2-{3}-01' -f $cfg.product, $c, $cfg.environment, $t).ToLower() }
$rg = N rg
New-AzResourceGroup -Name $rg -Location $cfg.location | Out-Null

# 1. Spoke network. No inbound from the internet; app port only from the gateway subnet; default deny out.
$rules = @(
  New-AzNetworkSecurityRuleConfig -Name allow-ssh-from-hub-mgmt -Priority 100 -Direction Inbound -Access Allow -
Protocol Tcp -SourceAddressPrefix $cfg.hub.managementSubnet -SourcePortRange * -DestinationAddressPrefix
$cfg.stamp.appSubnet -DestinationPortRange 22
  New-AzNetworkSecurityRuleConfig -Name allow-app-from-gateway  -Priority 110 -Direction Inbound -Access Allow -
Protocol Tcp -SourceAddressPrefix $cfg.hub.applicationGatewaySubnet -SourcePortRange * -DestinationAddressPrefix
$cfg.stamp.appSubnet -DestinationPortRange $cfg.stamp.appPort
  New-AzNetworkSecurityRuleConfig -Name deny-internet-inbound   -Priority 4000 -Direction Inbound -Access Deny -
Protocol * -SourceAddressPrefix Internet -SourcePortRange * -DestinationAddressPrefix * -DestinationPortRange *
  New-AzNetworkSecurityRuleConfig -Name allow-out-azure-443     -Priority 100 -Direction Outbound -Access Allow -
Protocol Tcp -SourceAddressPrefix * -SourcePortRange * -DestinationAddressPrefix AzureCloud -DestinationPortRange
443
  New-AzNetworkSecurityRuleConfig -Name deny-outbound-all       -Priority 4000 -Direction Outbound -Access Deny -
Protocol * -SourceAddressPrefix * -SourcePortRange * -DestinationAddressPrefix * -DestinationPortRange *
)
$nsg = New-AzNetworkSecurityGroup -ResourceGroupName $rg -Name (N nsg-app) -Location $cfg.location -SecurityRules
$rules -Force
$sn  = @(
  New-AzVirtualNetworkSubnetConfig -Name snet-app -AddressPrefix $cfg.stamp.appSubnet -NetworkSecurityGroup $nsg
  New-AzVirtualNetworkSubnetConfig -Name snet-pe  -AddressPrefix $cfg.stamp.privateEndpointSubnet
)
$spoke = New-AzVirtualNetwork -ResourceGroupName $rg -Name (N vnet) -Location $cfg.location -AddressPrefix
$cfg.stamp.addressSpace -Subnet $sn -Force
$hub   = Get-AzVirtualNetwork -Name "$($cfg.product)-hub-$($cfg.environment)-eus2-vnet-01"
Add-AzVirtualNetworkPeering -Name to-hub      -VirtualNetwork $spoke -RemoteVirtualNetworkId $hub.Id
Add-AzVirtualNetworkPeering -Name "to-$c"     -VirtualNetwork $hub   -RemoteVirtualNetworkId $spoke.Id

# 2. Key Vault: RBAC mode, purge protection, private endpoint, public access closed when seeding ends
$kvName = (N kv) -replace '-',''
$kv = New-AzKeyVault -VaultName $kvName -ResourceGroupName $rg -Location $cfg.location -Sku Premium `
        -EnablePurgeProtection -SoftDeleteRetentionInDays 90 -PublicNetworkAccess Disabled
$pls = New-AzPrivateLinkServiceConnection -Name "$kvName-conn" -PrivateLinkServiceId $kv.ResourceId -GroupId
vault
New-AzPrivateEndpoint -ResourceGroupName $rg -Name (N pe-kv) -Location $cfg.location `
  -Subnet ($spoke.Subnets | Where-Object Name -eq snet-pe) -PrivateLinkServiceConnection $pls | Out-Null
# Add the privatelink.vaultcore.azure.net zone, link it to the spoke, and attach a zone group (omitted for
length)
```

```
# 3. Customer-managed key + disk encryption set (double encryption, auto rotation)
$key = Add-AzKeyVaultKey -VaultName $kvName -Name cmk-disk-encryption -Destination HSM -KeyType RSA -Size 3072
$desCfg = New-AzDiskEncryptionSetConfig -Location $cfg.location -SourceVaultId $kv.ResourceId -KeyUrl
$key.Key.Kid `
            -IdentityType SystemAssigned -EncryptionType EncryptionAtRestWithPlatformAndCustomerKeys -
RotationToLatestKeyVersionEnabled $true
$des = New-AzDiskEncryptionSet -ResourceGroupName $rg -Name (N des) -DiskEncryptionSet $desCfg
New-AzRoleAssignment -ObjectId $des.Identity.PrincipalId -RoleDefinitionName 'Key Vault Crypto Service Encryption
User' -Scope $kv.ResourceId

# 4. VM: Trusted Launch, system-assigned identity, encryption at host, CMK disks, NO public IP
$nic = New-AzNetworkInterface -ResourceGroupName $rg -Name (N nic) -Location $cfg.location -SubnetId
($spoke.Subnets | Where-Object Name -eq snet-app).Id
$vm  = New-AzVMConfig -VMName (N vm) -VMSize $cfg.stamp.vmSize -SecurityType TrustedLaunch -IdentityType
SystemAssigned -EncryptionAtHost $true
$vm  = Set-AzVMUefi -VM $vm -EnableVtpm $true -EnableSecureBoot $true
$vm  = Set-AzVMOperatingSystem -VM $vm -Linux -ComputerName (N vm) -Credential (Get-Credential) -PatchMode
AutomaticByPlatform
$vm  = Set-AzVMSourceImage -VM $vm -PublisherName Canonical -Offer ubuntu-24_04-lts -Skus server -Version latest
$vm  = Set-AzVMOSDisk -VM $vm -CreateOption FromImage -StorageAccountType Premium_LRS -DiskEncryptionSetId
$des.Id
$vm  = Add-AzVMNetworkInterface -VM $vm -Id $nic.Id
New-AzVM -ResourceGroupName $rg -Location $cfg.location -VM $vm
$vmObj = Get-AzVM -ResourceGroupName $rg -Name (N vm)

# 5. VM -> IMDS -> Key Vault: the identity may READ secrets, nothing else
New-AzRoleAssignment -ObjectId $vmObj.Identity.PrincipalId -RoleDefinitionName 'Key Vault Secrets User' -Scope
$kv.ResourceId

# 6. Backup: Recovery Services vault, geo-redundant to the paired region, cross-region restore, immutability
$rsv = New-AzRecoveryServicesVault -ResourceGroupName $rg -Name (N rsv) -Location $cfg.location
Set-AzRecoveryServicesBackupProperty -Vault $rsv -BackupStorageRedundancy GeoRedundant
Set-AzRecoveryServicesBackupProperty -Vault $rsv -EnableCrossRegionRestore
Update-AzRecoveryServicesVault -ResourceGroupName $rg -Name $rsv.Name -ImmutabilityState Unlocked -
PublicNetworkAccess Disabled
$pol = Get-AzRecoveryServicesBackupProtectionPolicy -VaultId $rsv.ID -Name EnhancedPolicy
New-AzResourceGroup -Name "AzureBackupRG_$($cfg.location)_1" -Location $cfg.location -Tag @{ Owner='<owner>';
Client='<client>'; DataClassification='Confidential' }  # pre-create tagged, or tag policy refuses it
Enable-AzRecoveryServicesBackupProtection -VaultId $rsv.ID -Policy $pol -Name $vmObj.Name -ResourceGroupName $rg

# 7. Exit criterion: Key Vault read by the VM identity only
Get-AzRoleAssignment -Scope $kv.ResourceId | Select-Object DisplayName, RoleDefinitionName, ObjectType
```

FETCH-SECRETS.TEMPLATE.SH · ON THE VM · READ SECRETS WITH THE MANAGED IDENTITY BASH

```
#!/usr/bin/env bash
# SOP-02 template: on the VM, read secrets with the managed identity (VM -> IMDS -> Key Vault).
# No secret, key or connection string is stored on disk in the image or in source control.
set -euo pipefail
VAULT="<vault-name>"                        # e.g. app-c001-prd-eus2-kv-01 without dashes
API="api-version=7.4"
TOKEN=$(curl -s -H "Metadata: true" \
  "http://169.254.169.254/metadata/identity/oauth2/token?api-version=2018-02-
01&resource=https%3A%2F%2Fvault.azure.net" \
  | python3 -c 'import sys,json; print(json.load(sys.stdin)["access_token"])')
get() { curl -s -H "Authorization: Bearer $TOKEN" "https://$VAULT.vault.azure.net/secrets/$1?$API" \
        | python3 -c 'import sys,json; print(json.load(sys.stdin)["value"])'; }
umask 077
{
  echo "JWT_SECRET=$(get app-jwt-secret)"
  echo "BACKUP_CONNECTION=$(get app-backup-storage-connection)"
} > /run/app/env            # tmpfs, readable by the service user only, gone at reboot
```

EXAMPLE · ONBOARDING THE NEXT CUSTOMER POWERSHELL

```powershell
# copy the parameter file, change customerCode and the spoke address space only
(Get-Content tenant.parameters.json | ConvertFrom-Json) | ForEach-Object { $_.customerCode = 'c002';
$_.stamp.addressSpace = '10.2.0.0/16'; $_ } |
  ConvertTo-Json -Depth 10 | Set-Content tenant.c002.parameters.json
./SOP-02-customer-stamp.ps1 -ParameterFile ./tenant.c002.parameters.json -WhatIf
```

CHAPTER 5

Verification and Troubleshooting

5.1 Verify the stamp

- [ ] `Get-AzRoleAssignment -Scope <vault id>` lists only the VM identity (Secrets User) and the disk set (Crypto Service Encryption User).
- [ ] `Get-AzNetworkInterface` shows no public IP configuration on the VM NIC.
- [ ] `Get-AzRecoveryServicesBackupProperty` reads GeoRedundant and cross-region restore True.
- [ ] One on-demand backup completed; job ID and time recorded.
- [ ] From outside the network, listing vault secrets is refused (SOP-AZ-105).

5.2 Troubleshooting

Symptom	Likely cause and fix
VM create fails on size	Zero quota or capacity restriction for that family. Request quota or choose another size.
VM create fails on disk controller	v6 sizes are NVMe-only. Set the disk controller type to NVMe.
Service cannot read secrets	Missing Secrets User role, role not yet propagated, or private DNS zone not linked to the spoke.
First backup fails with a policy error	Azure Backup tried to create an untagged `AzureBackupRG_*` group. Pre-create it with the required tags.
Cannot set GRS on the vault	An item is already protected. Stop protection (retain data), change redundancy, protect again.

5.3 Rollback

Stop backup protection with retain data, then remove the stamp resource group. The vault's purge protection keeps it recoverable for 90 days, and the disk encryption key must stay until every recovery point that used it has expired.

CHAPTER 6

Summary, Glossary and Review

6.1 Chapter summary

- Every customer gets an identical stamp from one template and one parameter.
- Secrets travel VM → IMDS → private endpoint → vault, and the VM can only read.
- Disks use a customer-managed key; backups go geo-redundant to the paired region.
- Redundancy is set before the first backup, because it locks afterwards.

Check your understanding

1. What does IMDS give the VM, and what does the VM do with it?
2. Why is the VM's only vault role Key Vault Secrets User?
3. What happens if you enable VM backup before setting Geo-redundant?
4. Why does the template pre-create the AzureBackupRG resource group?
5. Which two parameters change when onboarding the next customer?

6.2 Glossary

Stamp	One isolated, identical deployment unit per customer.
IMDS	Instance Metadata Service; issues tokens for the VM managed identity.
Managed identity	An Entra identity owned by an Azure resource, with no password to store.
CMK	Customer-managed key: the client controls the key that encrypts the disks.
Cross-region restore	Restore from the paired region copy without waiting for a Microsoft failover.

6.3 Framework references

Framework	Controls
CIS Azure Foundations	7.x, 8.x
NIST SP 800-53 R5	SC-7, SC-12, SC-28, IA-5, CP-9, CP-10
ISO/IEC 27001:2022	A.8.13, A.8.20, A.8.24
HIPAA Security Rule	164.308(a)(7), 164.312(a)(2)(iv)